

夸父项目 Bug 与设计缺陷审计报告

审计日期: 2026-03-17

审计范围: 后端 Python、前端 React/TypeScript、配置与数据文件

汇总统计

严重程度	后端	前端	配置/数据	合计
高 (High)	7	6	3	16
中 (Medium)	15	8	7	30
低 (Low)	3	6	7	16
合计	25	20	17	62

一、安全类问题 (最高优先级)

S-1. API 密钥硬编码在配置文件中 [HIGH]

- 文件: config/llm.json:19,37,51,69
- 描述: DeepSeek、Volcano、ZhiPu、Local 等多个真实 API Key 以明文写在 JSON 中，且该文件已提交 Git
- 建议: 迁移至环境变量，config 文件只保留占位符，.gitignore 排除敏感配置

S-2. QQ Bot 凭据硬编码 [HIGH]

- 文件: config/qq_bot.json:3-5
- 描述: client_secret 和 admin_openid 明文存储
- 建议: 同 S-1

S-3. CORS 允许所有来源 [HIGH]

- 文件: main.py:547
- 描述: allow_origins=["*"] 允许任何域发起请求
- 建议: 生产环境配置域名白名单

S-4. 路径遍历风险 - 工具沙箱 [HIGH]

- 文件: tools/tool_ll.py:53-83
- 描述: _resolve_safe_path() 未校验 .. 目录遍历，用户可通过 ../../../../ 访问项目外文件
- 建议: 使用 fp.relative_to(allowed_base) 确保路径在允许范围内

S-5. Markdown 渲染未做 HTML 消毒 [LOW]

- 文件: `static/src/components/Player/PlayerInput.tsx:220`
 - 描述: `ReactMarkdown` + `remarkGfm` 未配置 HTML 过滤, 若 NPC 回复含恶意 HTML 存在 XSS 风险
 - 建议: 添加 `rehype-sanitize` 插件
-

二、后端 - 线程安全与并发问题

B-1. 全局状态字典无同步保护 [HIGH]

- 文件: `core/social/social_l1.py:16-24`
- 描述: `_player_input_queue`、`_conversation_state`、`_last_conversation_partners` 等全局可变字典在多个异步任务/线程中修改, 无 Lock 保护
- 影响: 多个对话并发时可能出现状态损坏、前端读到脏数据
- 建议: 使用 `threading.Lock` 或 `asyncio.Lock` 包装所有全局状态修改

B-2. 玩家输入等待无超时 [MEDIUM]

- 文件: `core/social/social_l1.py:82-98`
- 描述: `wait_for_player_input()` 是无限 `while True` 循环, 无超时退出机制
- 影响: 玩家不回复时对话永远挂起, 前端冻结
- 建议: 添加超时参数 (默认 5 分钟), 超时后自动结束对话

B-3. 世界状态重置无同步 [MEDIUM]

- 文件: `main.py:118-159`
 - 描述: `reset_world_state()` 修改全局 `npcs` 变量时, 主循环可能正在遍历
 - 建议: 添加锁或使用原子替换
-

三、后端 - 异常处理问题

B-4. 裸 except 吞没所有异常 [HIGH]

- 文件: `main.py:1019`
- 描述: `except: pass` 静默吞掉世界加载中的所有异常, 包括系统级异常
- 建议: 至少 `except Exception as e: logging.exception(e)`

B-5. 异常只打印不记录堆栈 [MEDIUM]

- 文件: `main.py:1262`, `core/social/social_l1.py:237`
- 描述: 多处 `except Exception as e: print(f"...: {e}")` 丢失了调用栈信息
- 建议: 使用 `logging.exception()` 或 `traceback.print_exc()`

B-6. 世界切换端点缺少异常处理 [MEDIUM]

- 文件: `main.py:1036-1070`
 - 描述: `/api/world/switch` 加载 HJL、写运行时文件、重初始化模块均无 try-except
 - 建议: 包装在统一异常处理中
-

四、后端 - 空值与类型安全

B-7. listener 可为 None 但未检查 [HIGH]

- 文件: `core/social/social_l1.py:348`
- 描述: 工具执行时 `listener` 可能为 None, 但直接传入 handler context
- 影响: handler 访问 `listener.name` 时触发 `AttributeError`

B-8. LLM 返回格式未验证 [MEDIUM]

- 文件: `tools/llm_client.py:144`
- 描述: `result.get("content_blocks", [])` — 如果 LLM 返回意外格式, `content_blocks` 可能为 `None` (非缺失)
- 建议: `result.get("content_blocks") or []`

B-9. 模型配置回退为空字典 [MEDIUM]

- 文件: `tools/llm_l2.py:88`
- 描述: `models.get(model_name, {})` 返回空字典, 下游代码期望特定 key 时会 `KeyError`
- 建议: 使用包含所有必需键的默认配置

B-10. tool_l1 中 max_chars 类型转换 [MEDIUM]

- 文件: `tools/tool_l1.py:96`
- 描述: `int(input_obj.get("max_chars", 100000))` — 如果 `max_chars` 是非数字字符串, `int()` 抛 `ValueError`
- 建议: 添加 try-except 或预校验

B-11. spawn 返回值可能为 None [HIGH]

- 文件: `tools/loader_l1.py:62`
 - 描述: `_get_spawn_point()` 可能返回 `None`, 后续访问 `spawn["x"]` 会崩溃
 - 建议: 添加 `None` 检查和默认坐标
-

五、后端 - 逻辑缺陷

B-12. 碰撞禁止只检查单向 [MEDIUM]

- 文件: `core/drive/drive_l1.py:111`
- 描述: `is_banned = (npc_a.ban_target_uuid == npc_b.name)` 只检查 A 屏蔽 B, 不检查 B 屏蔽 A
- 影响: B 仍然会与 A 碰撞互动
- 建议: 双向检查

B-13. 墙壁反弹方向覆盖 [LOW]

- 文件: `core/drive/drive_l2.py:59-65`
- 描述: X/Y 同时碰壁时, 第二次方向赋值覆盖第一次, 导致反弹角度错误
- 建议: 使用组合反弹逻辑

B-14. 行号索引不一致 [MEDIUM]

- 文件: `tools/tool_l1.py:118-123`
- 描述: `start_line` 从 1 索引转 0 索引, 但 `end_line` 未做相同转换, 切片范围不正确
- 建议: 统一文档化索引约定并一致转换

B-15. 主动值恢复无上限保护 [MEDIUM]

- 文件: `core/drive/drive_l1.py:22-24`
- 描述: `npc.initiative += 1` 未检查 `max_initiative` 是否为 0 或负数
- 建议: 添加边界检查

六、后端 - 资源泄漏与内存

B-16. MCP 连接失败时资源未释放 [HIGH]

- 文件: `tools/mcp_client_l1.py:48-97`
- 描述: `AsyncExitStack` 连接失败时可能未正确清理, 文件描述符泄漏
- 建议: 使用 try-finally 确保 cleanup

B-17. Skill 缓存无限增长 [MEDIUM]

- 文件: `tools/skill.py:13`
- 描述: `SKILL_CACHE = {}` 无驱逐策略, 长时间运行后内存持续增长
- 建议: 使用 LRU Cache 或限制大小

B-18. MCP 会话缓存无清理 [MEDIUM]

- 文件: `tools/mcp_client.py:15-26`
 - 描述: `_sessions` 和 `_tool_defs_cache` 只增不减
 - 建议: NPC 删除时清理对应缓存
-

七、后端 - API 设计问题

B-19. DELETE 端点使用请求体 [MEDIUM]

- 文件: `main.py:1384-1399`
- 描述: `@app.delete("/api/tasks/{npc_name}")` 依赖请求体中的 `hint` 字段, FastAPI DELETE 默认不解析 body
- 建议: 使用 `Body()` 显式声明或改为 POST

B-20. API 响应格式不统一 [MEDIUM]

- 文件: `main.py` 多处
- 描述: 部分端点返回 `{"status": "ok", ...}`, 部分无 status 字段 (如 `/api/status`、`/api/npcs`)
- 建议: 统一所有响应包含 status 字段

B-21. 工具 handler 返回类型不一致 [LOW]

- 文件: `tools/tool_l1.py` 多处
- 描述: 部分返回错误字符串, 部分返回 `{"status": "error", "message": ...}` 字典
- 建议: 统一错误返回格式

B-22. 可变默认参数 [MEDIUM]

- 文件: `main.py:1189`
- 描述: `async def god_deselect(request: dict = {})` 使用可变默认参数, 可能导致跨请求状态污染
- 建议: 改为 `request: dict = None`

B-23. NPC 创建缺少名称校验 [LOW]

- 文件: `main.py:450-509`
 - 描述: `/api/npc/create` 只做了 `name.strip()`, 未校验空字符串、特殊字符、长度限制
 - 建议: 添加正则校验
-

八、后端 - 数据格式问题

B-24. HJL 文件缺少 graph 节点 [MEDIUM]

- 文件: `data/individuals/*.hjl`
- 描述: CLAUDE.md 规范要求三大根节点 `header`、`attributes`、`graph`，实际文件缺少 `graph`（动态知识图谱）
- 建议: 补充 `graph` 节点或更新规范

B-25. NPC 位置格式不一致 [LOW]

- 文件: `data/individuals/boss.hjl:6-8`
- 描述: `boss.hjl` 使用简单 `{x, y}` 格式，其他 NPC 使用 `"world:scene": {x, y}` 格式
- 建议: 统一位置数据结构

B-26. RAM Buffer 数据格式混用 [LOW]

- 文件: `core/social/social_l1.py`, `core/mem/mem_l1.py`
- 描述: `ram_buffer` 有时是 `{"role": ..., "content": ...}` 字典，有时是纯字符串，解析时需双重判断
- 建议: 统一为字典格式

九、前端 - 内存泄漏

F-1. HTTP 响应未校验 `res.ok` [HIGH]

- 文件: `static/src/store/useWorldStore.ts:59,76,89,118`
- 描述: 多个 `fetch()` 调用未检查 `res.ok` 就直接 `res.json()`，服务器返回 4xx/5xx 时 JSON 解析失败
- 建议: 统一添加 `if (!res.ok) throw new Error(...)`

F-2. PlayerInput 轮询组件卸载后未停止 [HIGH]

- 文件: `static/src/components/Player/PlayerInput.tsx:80-124`
- 描述: 组件卸载时如果对话仍在进行，`setInterval` 不会被清除
- 建议: 使用 `ref` 跟踪挂载状态，卸载时清除

F-3. useDraggable 事件监听器泄漏 [HIGH]

- 文件: `static/src/hooks/useDraggable.ts:62-72`
- 描述: `mousemove/mouseup` 监听器在 `isDragging` 条件块内添加，组件卸载时可能未正确移除
- 建议: 始终在 `useEffect cleanup` 中移除，不受条件限制

F-4. MemoryChat 请求竞态 [HIGH]

- 文件: `static/src/components/GodMode/MemoryChat.tsx:137-167`
- 描述: 快速滚动时多个并发 API 请求无取消机制, npcName 变化后旧请求仍可能更新状态
- 建议: 使用 `AbortController` 取消过期请求

F-5. MemoryChat useEffect 依赖错误 [HIGH]

- 文件: `static/src/components/GodMode/MemoryChat.tsx:126`
- 描述: 依赖项为 `[messages.length > 0 && loadedCount === PAGE_SIZE]`, 布尔表达式每次渲染生成新值, 导致 effect 频繁触发
- 建议: 改为 `[messages.length, loadedCount]`

F-6. MemoryChat 卸载后 setState [MEDIUM]

- 文件: `static/src/components/GodMode/MemoryChat.tsx:162-163`
- 描述: `.finally(() => setLoading(false))` 可在组件卸载后触发
- 建议: 使用挂载状态 ref 守卫

十、前端 - 设计缺陷

F-7. window.location.reload() 滥用 [HIGH]

- 文件: `static/src/store/useWorldStore.ts:103,130`
- 描述: Store action 调用 `window.location.reload()` 强制刷新页面, 丢失所有 React 状态
- 建议: 通过 Store 状态更新驱动 UI 刷新

F-8. 轮询频率过高 [MEDIUM]

- 文件: `static/src/App.tsx:36-41`
- 描述: `usePolling()` 每 500ms 拉取 status/NPCs/god/conversation 四个接口, 每秒 8 次请求。各子组件还各自轮询
- 建议: 降低频率或使用 WebSocket / SSE

F-9. 重复拉取相同数据 [MEDIUM]

- 文件: `static/src/App.tsx:36-49`
- 描述: `fetchStatus()` 同时在 `usePolling(500ms)` 和 `useEffect(mount)` 中调用
- 建议: 去除重复调用

F-10. 数组索引作为 React key [LOW]

- 文件: `static/src/components/Player/PlayerInput.tsx:192`
- 描述: `messages.map((msg, idx) => <div key={idx}>)` — 数组增删时导致 React 错误匹配
- 建议: 使用消息唯一 ID

F-11. Stale Closure 风险 [MEDIUM]

- 文件: `static/src/components/Player/PlayerInput.tsx:80-124`
- 描述: `poll` 函数捕获的 `talkingNPCs` 可能是旧值
- 建议: 使用 `ref` 缓存最新值

F-12. FormStore 未处理非 ok 状态 [MEDIUM]

- 文件: `static/src/store/useFormStore.ts:40,72,96`
- 描述: 只检查 `data.status === 'ok'`, `else` 分支无处理, 函数隐式返回 `undefined`
- 建议: 添加错误状态处理

F-13. 缺少 Error Boundary [LOW]

- 文件: 全局
- 描述: 无 React Error Boundary, 任何渲染崩溃导致整个应用白屏
- 建议: 添加顶层 Error Boundary 组件

F-14. Store 错误处理不统一 [LOW]

- 文件: 各 store 文件
- 描述: 部分 `catch` 记录错误, 部分 `catch {}` 静默吞掉
- 建议: 统一错误处理模式

优先修复建议 (Top 10)

优先级	编号	问题	理由
1	S-1/S-2	API 密钥泄露	安全风险最高, 已入库
2	S-4	路径遍历漏洞	可被利用读取任意文件
3	B-1	全局状态无锁	生产环境并发崩溃
4	B-4	裸 <code>except</code> 吞异常	隐藏关键错误, 无法排障
5	B-16	MCP 连接资源泄漏	长时间运行耗尽资源
6	F-1	HTTP 响应未校验	服务异常时前端级联崩溃
7	F-5	<code>useEffect</code> 依赖错误	性能问题 + 不可预测行为

优先级	编号	问题	理由
8	F-7	reload() 滥用	破坏用户体验
9	B-2	玩家输入无超时	对话永久挂起
10	F-8	轮询过于频繁	服务器压力大，浪费带宽

本报告仅列出发现，未进行代码修改。建议按优先级逐步修复。